

Data Classification Quick Reference Guide

A one-page summary for all HealthPlus Medical Group employees, contractors, and vendors. For full detail, see the Data Classification Policy (POL-SEC-005).

The 4 Classification Levels

Level	What It Means	Examples
 PUBLIC	Safe for anyone to see	Marketing materials, website content, press releases
 INTERNAL	For HealthPlus staff only	Memos, org charts, internal newsletters
 CONFIDENTIAL	Could harm someone if leaked	Employee PII, financial data, contracts
 RESTRICTED	Could cause severe harm — top protection	Patient records (PHI), passwords, encryption keys

Rule of thumb: If in doubt, treat it as the higher classification until confirmed. If a document mixes levels, protect the whole thing at the highest level it contains.

What to Do at Each Level

	 Public	 Internal	 Confidential	 Restricted
Label it?	No	Yes — "Internal Use Only"	Yes — "CONFIDENTIAL"	Yes — "RESTRICTED — PHI"
Encrypt when stored?	No	Recommended	Yes	Yes — always
Encrypt when sent?	No	Recommended	Yes	Yes — always, no exceptions

Who can access it?	Anyone	All employees	Need-to-know only, manager-approved	Need-to-know only, formally approved + logged
Can I email it normally?	Yes	Yes (company email)	No — use encrypted email/secure transfer	No — use approved secure/EHR channels only
Can I store it on my laptop/USB/personal cloud?	Yes	Company systems only	No	Absolutely not
How do I dispose of it?	Regular trash/delete	Shred/delete	Cross-cut shred or certified digital wipe	Certified destruction + logged sanitization (NIST 800-88)

Quick Do's and Don'ts

Do:

- Label Confidential and Restricted documents clearly
- Use the EHR's secure messaging or company-approved encrypted email for PHI
- Store patient and financial data only in approved systems
- Shred paper records containing PII or PHI — never toss them in regular trash
- Ask your manager or the Privacy Officer if you're unsure how to classify something

Don't:

- Send PHI, PII, or financial data to your personal email
- Save patient or employee data to a personal laptop, phone, or USB drive
- Use personal cloud storage (Dropbox, personal Google Drive, etc.) for any Confidential or Restricted data
- Text or use personal messaging apps to share patient information

- Throw away old hard drives, phones, or paper records containing PHI without proper sanitization/destruction

Who to Contact

Question	Contact
How do I classify this data?	Your manager or the Data Owner for that system
I think I mishandled or exposed sensitive data	Privacy Officer: andrei@cyberdlh.lu , or IT Service Desk immediately
I need to send Restricted data externally	Contact the Privacy Officer first — a Business Associate Agreement may be required
I found data that looks unclassified or mislabeled	IT Security or your manager

Remember: Patient trust and HealthPlus's compliance with HIPAA and GDPR depend on everyone handling data correctly, every time.